Quem audita os sistemas do SENAI não consegue saber, rápido, se eles usam bibliotecas com falhas conhecidas.

QUEM SOFRE

O auditor, que analisa os sistemas do SENAI sem ser especialista em segurança, e os times que corrigem.

QUANDO ACONTECE

Sob demanda: sempre que o auditor decide analisar um sistema.

COMO É HOJE

Não há ferramenta para isso no processo. Quando alguém olha, é pesquisa manual, falha por falha.

Resultado: triagem lenta e falhas já conhecidas chegando à produção.

O Rastro lê a navegação gravada de um site e diz o que corrigir primeiro.

COMO FUNCIONA

1. Grave
Navegue pelo site e exporte o HAR no DevTools.

2. Identifique
IA

Bibliotecas e versões. Em bundles, a IA lê o código.

3. Consulte
GitHub Advisory: falhas e chance de exploração.

4. Priorize
Nota fixa e explicável: gravidade + exploração.

5. Aja
IA

O que corrigir, explicado pela IA, com task pronta.

No MVP

- CLI + relatório HTML
- GitHub Advisory (OSV e NVD, se der)
- Bibliotecas, cabeçalhos e cookies
- Só análise passiva

Fica de fora

- Scan ativo (envio de ataques)
- Análise de código-fonte
- Integração com Azure DevOps
- Outras fontes: KEV, Vulners

Stack

- Python, biblioteca padrão
- IA: Kiro (padrão), Claude ou Codex
- React no relatório
- pytest-cov · Windows e Linux

Em três sites reais, nenhuma biblioteca inventada e todas as 30 falhas válidas encontradas.

0

bibliotecas confirmadas fora do gabarito, com e sem IA

30/30

falhas válidas do gabarito encontradas

+1

biblioteca achada só pela IA, num bundle; 1 sugestão barrada pelas travas

?

tempo de triagem manual: pendente, medido com uma pessoa

Tempo e custo das 3 análises (WebGoat, Drupal, Juice Shop)

- Sem IA: 14 s · Kiro: 3 min 29 s · Claude: 2 min 15 s e 410 mil tokens (13 chamadas)
- Kiro não informa tokens · Codex não medido: chave de API expirada na máquina